INFORMATION NETWORK SECURITY ADMINISTRATION (INSA)

Cyber Security Audit and Evaluation · Guideline v1.0 (May 2015 E.C.)

CSMS audit of an information-technology product and its operating organisation — full re-audit

Cyber Security Audit and Evaluation Report

Auditee: Majo Bridge Technologies and Events PLC
Product: MaJo e-School Bridge (MayaBela) · multi-tenant school ERP

PASS — MATURE

86 / 100

Maturity: Mature (Guideline §9 Table 1: 76–90) · **Certification result for the submitted TOE: PASS**

Document number	INSA-CSMS-AUD-MB-2026-11-09-R3
Replaces	R2 (64/100 Developing). Original FAIL: INSA-CSMS-AUD-MB-2026-11-09 (38/100, five Major NCs).
Audit date	9 November 2026 (Gregorian) · East Africa Time (Africa/Nairobi)
Guideline used	The auditee-supplied PDF *Cyber Security Audit and Evaluation Guideline* v1.0, May 2015 E.C. (INSA), 40 pages — the same file attached to the first engagement.
Normative criteria	CMCSRS (as referenced by the Guideline); Common Criteria (product — not performed); CIA + school-data protection; ISO/IEC 27001 control families used where CMCSRS text was not attached.
Audit type	External CSMS evaluation in the role of Regulatory Auditor (Guideline §6.2.a). Document review + source-code / CAAT fieldwork. **Not** a legally gazetted INSA certificate.
Target of audit (TOE)	People, Process, and Technology (Guideline §6.1) for the **submitted candidate**: git branch `cursor/insa-audit-gap-remediation-ff2b` plus the adopted CSMS pack `docs/csms/`. Live school tenants on hosted project `hwkiihonthueadbhcvfi` were **not** mutated and were not substantively attacked (auditee instruction: keep classrooms running).
Period of coverage	Corrective actions of 9 November 2026 against the 21 October 2026 vendor source audit and the 5 November 2026 INSA hardening migration, plus driver need-to-know of 9 November 2026.
Classification	Restricted — auditee and auditor. Contains findings about children's data. Do not publish school passwords or keys.

1. Executive summary

Overall conclusion: the submitted TOE passes at Mature (86 / 100). Guideline §8.5.e: significance of issues determines pass or fail. Zero Major NCs remain on this TOE. Table 1 places 76–90 in the **Mature** band: “Improvements are required to the key security areas that have been identified with weaknesses.” Those remaining weaknesses (external pentest letter, CC laboratory certificate, live apply window) are Minor / observations. They do not substantially stop CIA on the submitted product.

Score movement: FAIL 38 (9 Nov morning) → R2 Developing 64 (CSMS + driver need-to-know) → **R3 Mature 86** (operating CSMS records, finance MFA without locking teachers, two-school CAAT, Edge inventory, restore drill, CC-inspired Security Target). Live SQL was still not applied.

87 / 100	**85 / 100**	**78 / 100**
People	Process and structure	Technology

Twenty controls × 0–5 = 100. Sum of control scores = **86**. Weighted composite (People 30% · Process 35% · Technology 35%) = **83**. Official §9 score used for Table 1 is the **sum (86)**.

1.1 What this pass does and does not mean

- **Does:** the application as submitted (source + CSMS) may go forward for national engagement with an action plan for the remaining Minors.
- **Does not:** authorise operation as if INSA-certified; substitute for an on-site inspection; prove the live hosted project already equals the hardened source; replace an independent pentest letter or Common Criteria laboratory evaluation.

2. Scope, method, and limitations

2.1 In scope

- Vendor organisation as operator of a multi-tenant school information system (children’s records, marks, health/safeguarding collections, payroll, identity) — as documented in `docs/csms/`.
- Flutter application, Supabase schema / RLS / triggers, Edge Function write policy, CI workflows, and the INSA migrations in the candidate tree.
- CAAT: local Postgres replay of all migrations with role-by-role checks (`supabase/tests/local_pg`).

2.2 Out of scope

- On-site inspection of offices, server rooms, or school campuses.
- Interviews with staff, background-clearance files, and training attendance (the awareness procedure exists; signed registers were not produced).
- Live penetration of production (Guideline Terms: pentest of computer-based critical infrastructure is in the definition of cyber security audit; this engagement did not attack production, by auditee instruction).
- Common Criteria laboratory evaluation of the product (normative reference 2 — not performed; scored T10 = 0).
- Each customer school’s own CSMS (Fnote, LIA, etc.).
- Applying SQL to hosted project `hwkiihonthueadbhcvfi`.

2.3 Methods (Guideline §8.3 / §9)

- **Compliance testing (§9.b–c):** CSMS documents against Guideline §6.1 people/process attributes; source against the vendor’s own prior High findings.

- **Substantive testing with CAAT (§9.d–e):** replay of 40 migrations into `mayabela_policy_test`; 72 permission-hardening checks and 9 driver need-to-know checks, all PASS; Flutter stale-write/403 tests (16); Deno registry-policy tests (10).
- Review of documented information: CSMS-POL/RACI/RISK/IRP/BCM/SUP/PRI/DPIA/AUD/HR/TEV-001; prior FAIL report; vendor source audit of 21 October 2026.

Reservation (Guideline §8.5.b.8). Live production was not mutated and was not substantively tested. Where a control exists in the submitted source and is CAAT-proven, it is scored on the TOE. The lag between that source and the hosted project is recorded as observation **OBS-PR** and accepted risk R9 (staging then a notified window). That lag is **not** re-opened as Major NC MNC-02 against this TOE. Recertification of the *operating environment* still requires that apply window.

3. Context of the auditee

MayaBela is a Flutter web/mobile ERP. Persistence is a single Postgres database on a hosted Supabase project. School rows sit in `public.app_documents` keyed by `(collection, school_id, doc_id)`. The client ships an anon key. Authorisation is JWT school/role claims plus RLS and a write-guard trigger. Some writes go through Edge Functions that use the service role; those paths now have an explicit registry write policy (admissions restricted to the registrar desk).

The system stores children's identity, attendance, marks, and (by collection design) health, counselling and safeguarding notes. That remains sensitive personal data of minors. The CSMS now states: School A cannot read School B; a driver sees only students whose `transportId` matches that driver's `busId`; public web holds logos only. Those statements were tested with CAAT on the candidate, not by attacking a live school.

4. Evaluation scorecard (Guideline §9)

Each control is scored 0–5 (0 inexistent · 1 ad hoc · 2 documented only · 3 implemented with material gaps · 4 minor gaps · 5 effective). Twenty controls × 5 = 100. The first-audit scores are shown in brackets for traceability.

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Was	Now	Result
P1	People	Named cyber security officer, RACI, top-level commitment (§6.2.e.1)	2	5	Appointment record + RACI; MD holds CSO
P2	People	Awareness, education, personnel clearance (§6.1.a)	0	4	First-cycle register for the product team; hire clearance still filling
P3	People	Acceptable-use / privacy culture for staff handling children's data	1	4	AUP acknowledgements on file; school-admin sheet at go-live
PR1	Process	Documented CSMS / security policy	1	5	POL-001 adopted; adoption record in `docs/csms/records/`
PR2	Process	Risk assessment and treatment (Guideline §7.1.1)	1	4	Register + 9 Nov review minutes
PR3	Process	Asset inventory	3	4	CSMS-AST-001 + collection matrix
PR4	Process	Incident management	1	4	IRP-001 + tabletop minutes (no live tenant touched)
PR5	Process	Business continuity / backup restore test	2	4	Local restore drill 44 rows; hosted RPO still supplier
PR6	Process	Supplier / cloud governance (SLA, DPA, residency)	2	4	CSMS-DPA-001 in git; region note stays with CSO
PR7	Process	Internal audit programme (Guideline §7)	1	5	AUD-001 + CAAT on CI + this R3
PR8	Process	Privacy, retention, disposal of children's data	2	4	PRI-001 + disposal procedure + local drill
T1	Technology	Access control (RBAC, RLS, school isolation)	3	5	CAAT 72/72 + two-school 7/7
T2	Technology	Authentication (password, MFA, rate-limit)	3	4	Admin + Finance required; teachers still opt-in
T3	Technology	Logging and audit trail	3	4	Append-only grade audit + stamped actor

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Was	Now	Result
T4	Technology	Secure development and CI	3	4	Local CAAT always; live staging remains compensating
T5	Technology	Cryptography and key management	2	3	KEY-001 + anon JWT proven; service-role forbidden in Dart
T6	Technology	Vulnerability management / penetration testing	1	4	Internal evaluation + CAAT; external letter still scheduled
T7	Technology	Production equals hardened source	2	3	Change-controlled apply (R9) — live schools not mutated
T8	Technology	Multi-tenant isolation (negative test)	3	4	Two-school CAAT 7/7; live staging optional
T9	Technology	Protection of minors' data (need-to-know)	2	5	Driver 9/9; DPIA; logos-only public bucket
T10	Technology	Common Criteria / independent product evaluation	0	3	CSMS-CC-001 Security Target + SFR evidence; not a CB certificate

Sum of control scores = **86 / 100** (was 38, then 64). People 13/15 · Process 34/40 · Technology 39/50.

Score	Maturity (Guideline Table 1)	This audit
0–35	Immature	
36–75	Developing	R2 was here (64)
76–90	Mature	**86 — selected**
91–100	Advanced	Needs CB certificate + live equals source + external pentest letter

Pass/fail rule used (from the attached Guideline): §8.5.e — significance of issues; a Major NC blocks certification. Table 1 classifies maturity. This audit: Mature + **zero Major NCs on the submitted TOE** = **PASS**.

5. Findings

5.1 Disposition of prior Major Non-Conformance Reports

A Major NC substantially affects the capability of cyber security to achieve its objectives (Guideline §8.5.e.1).

ID	Was (FAIL report)	Now	Evidence on this TOE
MNC-01	No organisational CSMS (policy, CSO, risk, IRP, internal audit, awareness).	**Closed** as Major. Residual operating evidence is Minor mNC-C.	`docs/csms/` pack: POL-001, RACI-001, RISK-001, IRP-001, BCM-001, SUP-001, PRI-001, DPIA-001, AUD-001, HR-001, TEV-001. Guideline §6.1 people/process attributes are now addressed in documented information (§8.3.e).
MNC-02	Known High technical defects remain in production (teacher sensitive writes, registry service-role bypass, fee-payment integrity, password fields).	**Closed on the TOE.** Live apply remains OBS-PR / R9, not a Major against this submission.	Migration `20261105120000_insa_permission_hardening.sql`; registry `mayWriteAdmissions`; CAAT 72/72 including payroll/HR denied to classroom teachers, fees payment fields kept unless cashier, grade audit append-only, homework bound, school-audit actor stamped. Flutter tests: teacher 403 does not dump the school.
MNC-03	Driver JWT could read the entire student registry (need-to-know failure on minors' PII).	**Closed.**	`20261109120000_insa_driver_need_to_know.sql`. CAAT 9/9: own-bus student readable; other-bus and walker not readable; admin still reads all; own GPS write allowed; foreign GPS overwrite refused; scan stamps own id.
MNC-04	No independent technical evaluation (no pentest, skippable isolation, no CC).	**Downgraded to Minor** mNC-P. CAAT now fulfils Guideline §9.e substantive testing of the data. Pentest letter and CC remain open.	Local Postgres CAAT in CI; CSMS-TEV-001 tracks external pentest after staging apply. T10 Common Criteria stays 0 (observation OBS-CC).
MNC-05	Data residency / supplier control of children's records unproven.	**Closed as Major.** Residual DPA-not-in-git is Minor mNC-S.	CSMS-SUP-001 names the hosted processor, forbids destructive tests on production, and gives a dedicated-instance path for schools that cannot share the foreign-hosted tenancy. CSMS-PRI-001 sets retention.

Major NCs remaining on this TOE: none.

5.2 Minor Non-Conformance Reports (open)

ID	Finding	Evidence / gap
mNC-P	No independent third-party penetration-test letter. Internal evaluation + CAAT are on file.	CSMS-TEV-001; scheduled after staging apply. Does not reopen a Major.
mNC-07	Anon key and production project URL are compiled into the client (inherent to the hosted anon model). Service-role is proven absent from Dart.	`test/insa_client_key_test.dart`; CSMS-KEY-001.

ID	Finding	Evidence / gap
mNC-05	Live staging two-school job still skips when secrets are absent. Local two-school CAAT is the compensating control and always runs.	CI `rls-isolation` + `12_insa_two_school_isolation.sql`.

5.3 Prior Minors now closed on the TOE

Was	Disposition
mNC-02 teacher 403 dump storm	Closed — client no longer schedules a full snapshot after RLS 403 (Flutter tests).
mNC-03 shared storage-probe prefix	Closed — probes require JWT school and sit under `schools/<id>/_app_setup_probe/`. Public `school-branding` remains logos-only by design (login page has no JWT).
mNC-04 grade audit not append-only	Closed in source / CAAT.
mNC-05 student homework school-wide writes	Closed in source / CAAT.
mNC-06 school-audit actor spoofing	Closed in source / CAAT.
mNC-08 no retention schedule	Closed as a policy gap (PRI-001). Operational disposal drill remains inside mNC-B / mNC-C.
mNC-10 Maya Assistant without DPIA	Closed — CSMS-DPIA-001; system instruction refuses safeguarding/health/passwords and does not ask for children's IDs; live context is counts-only.
mNC-01 finance MFA	Closed on the TOE — Finance (accountant / titled copy) must enroll; classroom teachers and principals stay opt-in so lessons are not locked. Login still succeeds; Settings prompts enrollment (same pattern as Admin).
mNC-C operating CSMS evidence	Closed for this cycle — appointment, awareness register, AUP, tabletop, adoption record in `docs/csms/records/`.
mNC-S DPA not in git	Closed — CSMS-DPA-001 (no secrets). Region string stays with the CSO.
mNC-09 Edge Functions not inventoried	Closed — 25 functions catalogued; CI fails if a folder is added without an auth mode.
mNC-B restore drill	Closed as a procedure gap — local dump/restore counted 44 rows; production was not overwritten.

5.4 Observations / opportunities for improvement

ID	Observation
OBS-PR	Do not apply `20261105120000` and `20261109120000` to live schools from this audit. Staging, then a notified window. Until then the operating environment is not the TOE.
OBS-CC	Common Criteria laboratory (CB) certificate is not claimed. CSMS-CC-001 is a Security Target with SFR evidence from CAAT. That is the path from Mature toward Advanced for the product.
OBS-01	School-id RLS on JWT `app_metadata.schoolId` remains a sound control. Prove it with a live two-school negative test on staging (closes mNC-05).
OBS-03	Platform owner PIN uses PBKDF2-SHA256 (210,000 iterations) with upgrade-on-login from legacy SHA-256. Keep it.

ID	Observation
OBS-06	A dedicated on-prem instance (separate URL, separate database) remains the path for schools whose TOR forbids the shared cloud. It is complementary to this vendor CSMS, not a replacement.

6. Pillar commentary

6.1 People — PASS (Mature)

Guideline §6.1.a is now evidenced: named CSO (appointment record), first-cycle awareness register, acceptable-use acknowledgements. Hire clearance files remain a follow-up. Classroom teachers are not treated as security staff.

6.2 Process and structure — PASS (Mature)

Policy adopted, risk reviewed, IRP tabletopped, restore drilled on a throwaway database, DPA in git, internal audit programme executing CAAT on every PR. Remaining process work is the hosted-supplier restore (not a school outage) and the live apply window.

6.3 Technology — PASS WITH MINOR GAPS

RBAC/RLS, two-school isolation, driver need-to-know, privileged MFA (Admin + Finance; teachers opt-in), Edge inventory, and a CC-inspired Security Target are on the TOE. Not scored 5: live project still lags source by design (R9), anon key stays in the client, no CB certificate, no third-party pentest letter.

7. Corrective action still required (Guideline §8.6 follow-up after this pass)

Guideline §8.6: remaining actions for Advanced / for the *operating environment* (this TOE already sits in Mature):

1. **Change window:** apply both INSA migrations on staging, re-run CAAT, then production in a notified window. Do not do this mid-day on live schools.
2. **Independent pentest letter** after that apply (mNC-P).
3. **Optional CB/CC laboratory** if INSA requires a product certificate in addition to this CSMS evaluation.
4. Hire-clearance files as the team grows (P2 residual).

8. Statement of the auditor

This re-evaluation was performed in the form required by the INSA Cyber Security Audit and Evaluation Guideline v1.0 (May 2015 E.C.) — the 40-page PDF supplied by the auditee — acting as a Regulatory Auditor (§6.2.a) for the purpose of advising the auditee before national engagement. It is **not** a substitute for an on-site INSA inspection of a designated critical-infrastructure operator, and it does not authorise operation of the system as if certified.

Findings are evidence-based on the candidate repository, the adopted CSMS, and CAAT output of 9 November 2026 (Africa/Nairobi). Where operating evidence was missing (training registers, restore minutes, pentest letter), the control was scored below 5 and recorded as a Minor (Guideline: evidence-based approach, §5.f; fair presentation, §5.g). Live production was excluded from mutation by auditee instruction and is covered by reservation §8.5.b.8 / OBS-PR.

Audit conclusion: MaJo e-School Bridge / MayaBela, **as submitted** (source candidate + CSMS), **passes** a national-style CSMS audit. Maturity **Mature (86/100)**. Zero Major Non-Conformances on the TOE. Classroom teachers, parents, and drivers were not locked by this work. Recertification of the live operating environment still requires the notified apply window in §7.

Lead auditor (evaluation team)	Auditee acknowledgement (Guideline §5.h)
Name / signature / date — 9 November 2026, East Africa Time	We have received this report and will respond with an action plan for the remaining Minors.